



Contoso Engineering (illustrative mock)

AI-SDLC roadmap G3

Secure, deliver and foundations

ASSESSMENT DATE	2026-09-27
FRAMEWORK VERSION	2.0.2
RESPONDENTS	14
GENERATED ON	2026-09-29

G3: Secure, deliver and foundations

ID	DIMENSION	SCORE	LEVEL	TARGET	GAP	PRIORITY	HORIZON
D6	Security and AI Supply Chain	1.90	L2 Adopting	3.00	1.10	P2 Medium	Semester
D7	Deliver and Operate	1.75	L2 Adopting	3.00	1.25	P2 Medium	Semester
D8	Engineering Foundations (AI amplifiers)	1.09	L1 Exploring	3.00	1.91	P1 High	Next quarter

D6: Security and AI Supply Chain

OWASP lists prompt injection (LLM01:2025), supply chain (LLM03:2025) and excessive agency (LLM06:2025) among the top risks [38], and agent goal hijack (ASI01) first for agentic applications [39]; NIST SP 800-218A adds practices for AI model development to the SSDF [40].

Low confidence: More than 30% of the answers are NA.

Start here

D6-Q5 AI supply chain (1.50, L1)

L3 target: A review process covers AI components; SBOMs and build provenance are produced for most builds.

Then L4: Provenance is verified at deployment (for example SLSA level targets); unvetted components are blocked automatically. [38][40][43][52]

D6-Q6 Threat modeling for AI features and agents (1.62, L2)

L3 target: Threat models are required for new AI features and agent workflows and reviewed by security.

Then L4: Threat models are updated after incidents and red-team exercises; controls are verified by automated tests. [38][39][40]

D6-Q4 Least privilege for agents (1.71, L2)

L3 target: Agent permissions are documented and reviewed; agents cannot reach production credentials or push to protected branches.

Then L4: Permissions are just-in-time and time-bound; access is reviewed automatically. [7][19][38][39]

Recommended strategies

- S6 Agentic Activation (P2 Medium, Semester)
- S7 Security & Governance (P2 Medium, Semester)

All questions in this dimension

ID	QUESTION	SCORE	N	NA	EVIDENCE
D6-Q1	Baseline scanning on every repository	2.00	7	7	4
D6-Q2	AI-assisted remediation	2.09	11	3	5
D6-Q3	Prompt injection defenses for agents	2.25	8	6	6
D6-Q4	Least privilege for agents	1.71	7	7	3
D6-Q5	AI supply chain	1.50	4	10	1
D6-Q6	Threat modeling for AI features and agents	1.62	8	6	1
D6-Q7	Audit trail for agent actions	2.08	12	2	4

D7: Deliver and Operate

more AI-generated change needs strong delivery safety nets [3], [5]; Microsoft recommends continuous observation of agent activity [19] and is extending agents to cloud operations [22].

Start here

D7-Q4 Observability of agents (1.57, L1)

L3 target: Agent runs emit telemetry to the central observability stack; dashboards show failures and cost per agent.

Then L4: Alerts fire on agent drift, error spikes or cost anomalies; findings feed governance (D1). [19][32][45]

D7-Q1 AI in CI/CD pipelines (1.69, L2)

L3 target: Pipelines are code in most repositories; AI-assisted failure analysis is available to all teams.

Then L4: Agents propose pipeline fixes and optimizations automatically, under review, with build time and failure rate tracked. [16][17]

D7-Q3 AI-assisted incident response (1.71, L2)

L3 target: On-call engineers in most teams use AI for triage and summaries; post-incident reviews record whether AI helped.

Then L4: Operations agents run approved diagnostics automatically; time to restore is compared before and after adoption. [16][17][22]

Recommended strategies

- S2 Foundry + SRE (P1 High, Next quarter)
- S6 Agentic Activation (P2 Medium, Semester)

All questions in this dimension

ID	QUESTION	SCORE	N	NA	EVIDENCE
D7-Q1	AI in CI/CD pipelines	1.69	13	1	4
D7-Q2	Progressive delivery and rollback	1.83	12	2	8
D7-Q3	AI-assisted incident response	1.71	14	0	6
D7-Q4	Observability of agents	1.57	14	0	5
D7-Q5	Infrastructure as code with guardrails	1.85	13	1	7
D7-Q6	Agent-driven operational automation	1.86	14	0	6

D8: Engineering Foundations (AI amplifiers)

DORA finds that these capabilities amplify the benefits of AI adoption, and that a high-quality internal platform correlates with the ability to unlock AI value [1], [3].

Start here

D8-Q7 Automated testing as a control system (0.75, L0)

L3 target: Most services have layered automated tests that run on every PR within agreed time budgets.

Then L4: Test suites are tuned from escaped-defect data; feedback time is tracked and improving. [3]

D8-Q4 Healthy data ecosystem (0.92, L1)

L3 target: Key data is cataloged with owners and quality indicators; most questions can be answered within an hour.

Then L4: Data quality is monitored automatically; lineage and contracts are in place for critical data. [1]
[2]

D8-Q5 Reproducible environments for humans and agents (1.00, L1)

L3 target: Most repositories define a reproducible environment; agents use the same definition.

Then L4: Environments start in minutes for any repository; drift from the definition is detected. [8]

Recommended strategies

- S2 Foundry + SRE (P1 High, Next quarter)
- S3 App Modernization (P1 High, Next quarter)
- S1 GitHub Migration (P1 High, Next quarter)

All questions in this dimension

ID	QUESTION	SCORE	N	NA	EVIDENCE
D8-Q1	Version control for everything	1.07	14	0	8
D8-Q2	Commit frequency and fast rollback	1.23	13	1	3
D8-Q3	Quality internal platform	1.29	14	0	5
D8-Q4	Healthy data ecosystem	0.92	13	1	6
D8-Q5	Reproducible environments for humans and agents	1.00	14	0	2
D8-Q6	Documentation as AI-ready context	1.36	14	0	8
D8-Q7	Automated testing as a control system	0.75	12	2	9

References

- [1] DORA. DORA AI Capabilities Model. Google Cloud, 2025. <https://dora.dev/ai/capabilities-model/report/>
- [2] DORA. DORA AI Capabilities Model: Survey Questions. Google Cloud, 2025. <https://dora.dev/ai/capabilities-model/questions/>
- [3] Google Cloud. Announcing the 2025 DORA Report: State of AI-Assisted Software Development. 2025. <https://cloud.google.com/blog/products/ai-machine-learning/announcing-the-2025-dora-report>
- [7] GitHub Docs. Risks and mitigations for GitHub Copilot cloud agent. <https://docs.github.com/en/enterprise-cloud@latest/copilot/concepts/security-governance-and-network-settings/risks-and-mitigations>
- [8] GitHub Docs. Best practices for using GitHub Copilot to work on tasks. <https://docs.github.com/en/enterprise-cloud@latest/copilot/tutorials/cloud-agent/get-the-best-results>
- [16] Microsoft Azure Blog. Agentic DevOps: Evolving software development with GitHub Copilot and Microsoft Azure. 2025. <https://azure.microsoft.com/en-us/blog/agentic-devops-evolving-software-development-with-github-copilot-and-microsoft-azure/>
- [17] Microsoft for Developers. Agentic DevOps in action: Reimagining every phase of the developer lifecycle. 2025. <https://developer.microsoft.com/blog/reimagining-every-phase-of-the-developer-lifecycle/>
- [19] Microsoft Learn. Govern and secure AI agents: Cloud Adoption Framework. <https://learn.microsoft.com/en-us/azure/cloud-adoption-framework/ai-agents/governance-security-across-organization>
- [22] Microsoft Azure Blog. Announcing Azure Copilot agents and AI infrastructure innovations. 2025. <https://azure.microsoft.com/en-us/blog/announcing-azure-copilot-agents-and-ai-infrastructure-innovations/>
- [32] Gartner. Gartner Predicts AI Coding Costs Will Surpass Average Developer's Salary by 2028 as Token Consumption Surges. 2026-06-24. <https://www.gartner.com/en/newsroom/press-releases/2026-06-24-gartner-predicts-ai-coding-costs-will-surpass-average-developer-salary-by-2028-as-token-consumption-surges>
- [38] OWASP GenAI Security Project. OWASP Top 10 for LLM Applications 2025. <https://genai.owasp.org/resource/owasp-top-10-for-llm-applications-2025/>
- [39] OWASP GenAI Security Project. OWASP Top 10 for Agentic Applications for 2026. 2025-12-09. <https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/>
- [40] NIST. SP 800-218A: Secure Software Development Practices for Generative AI and Dual-Use Foundation Models: An SSDF Community Profile. 2024-07. <https://csrc.nist.gov/pubs/sp/800/218/a/final>
- [43] OpenSSF. SLSA: Supply-chain Levels for Software Artifacts. <https://slsa.dev/>
- [45] Liu, B., Qiu, H., Goiri, Í., Fonseca, R., Bianchini, R., Choukse, E. Agentic Coding in the Wild: Characterizing GitHub Copilot Traces at Production Scale. arXiv:2608.00101, 2026-07-30. <https://arxiv.org/abs/2608.00101>
- [52] Sakib, A. H. M. N., Banik, D., Jadhwal, M. Trust but Verify? Uncovering the Security Debt of Autonomous Coding Agents. arXiv:2607.12428, 2026-07-14. <https://arxiv.org/abs/2607.12428>